

4.4 - Gerenciamento e rotação de chaves

O elo mais fraco de toda criptografia

O ciclo de vida de uma chave

Da geração à aposentadoria

- **Geração precisa de fonte de entropia confiável**
 - Chave fraca compromete todo o algoritmo forte
- **Armazenamento isola a chave do dado que ela protege**
 - HSM ou KMS guardam a chave fora da aplicação
- **Acesso é concedido por identidade, não por segredo**
 - A aplicação prova quem é, o KMS decide o uso
- **Rotação limita o dano de uma chave comprometida**
 - Chave antiga decifra histórico, chave nova cifra o novo

Chave na aplicação ou no KMS

Chave gerenciada pela aplicação

- Chave em variável de ambiente ou arquivo
- Vaza junto com o código ou o deploy
- Rotação manual, propensa a erro
- Sem trilha de auditoria de uso

Chave gerenciada por KMS ou HSM

- Chave nunca sai do cofre em texto claro
- Acesso controlado por política de identidade
- Rotação automatizada e versionada
- Cada uso registrado para auditoria

KMS e HSM gerenciados na prática

- **AWS KMS e Azure Key Vault gerenciam o ciclo completo**
 - Geração, rotação e auditoria como serviço gerenciado
- **HSM oferece isolamento físico validado por certificação**
 - FIPS 140 atesta resistência a extração da chave
- **Política de acesso amarra a chave a uma identidade**
 - A aplicação assume uma role, não carrega segredo
- **Rotação automática elimina a chave eterna e esquecida**

A chave que vazou num commit

- **LunaLog cifrava dados mas guardava a chave hardcoded**
 - Chave vivia em variável de ambiente do deploy

LUNALOG

A LunaLog implementou criptografia, mas guardou a chave mestra como variável de ambiente hardcoded no deploy. Dois meses depois, um desenvolvedor fez commit acidental de um arquivo de configuração com a chave para um repositório público. A rotação emergencial exigiu dezoito horas de trabalho, uma janela de manutenção de quatro horas e a recriptografia de todos os dados protegidos. Roberto passou a madrugada acordado coordenando o incidente. Um KMS gerenciado com rotação automatizada teria tornado esse episódio simplesmente impossível.

Rotação sem downtime em sistemas distribuídos

- **Versionar a chave permite decifrar dado antigo e novo**
- **Serviços buscam a chave do KMS, não a carregam embutida**

Rotação não é trocar uma chave por outra de uma vez. É manter ambas válidas durante a transição, senão você invalida todo o dado já cifrado.

- KMS gerenciado faz isso de forma transparente para a aplicação



Suas chaves estão protegidas, rotacionadas e auditadas. O sistema sabe que os dados estão seguros. Mas ele sabe quem está pedindo acesso a esses dados, e se esse acesso é legítimo? Existe uma confusão entre dois conceitos que, sozinha, cria uma classe inteira de vulnerabilidades.

Autenticação vs. autorização: revisão crítica